

Extending my ACCESS



by Pengrey



whoami

whoami

- Rodrigo Lima aka **Pengrey**

whoami

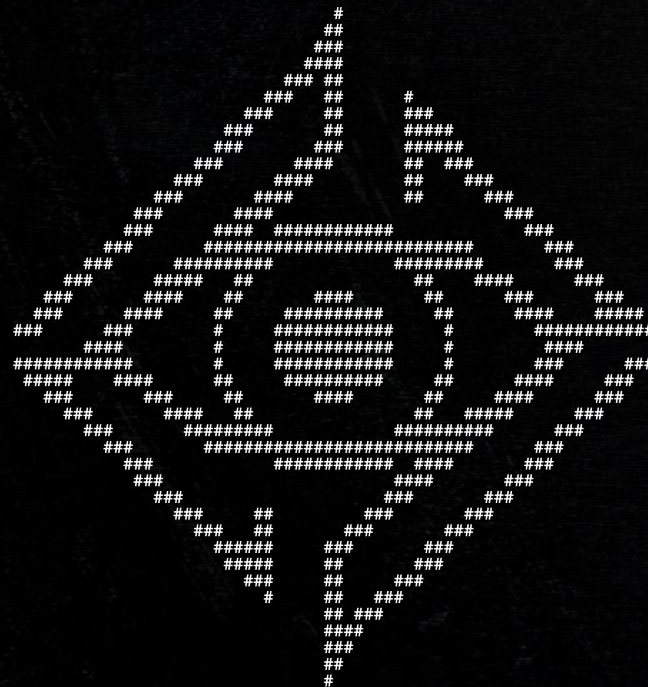
- Rodrigo Lima aka **Pengrey**
- **Red Team Operator** @ NOS

whoami

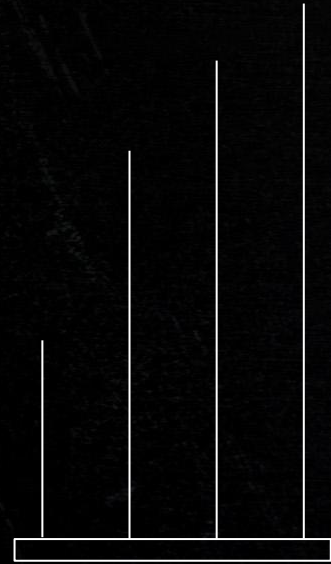
- Rodrigo Lima aka **Pengrey**
- **Red Team Operator** @ NOS
- **CTF Player** @ pwn_of_b4c4lh4u

whoami

- Rodrigo Lima aka **Pengrey**
- **Red Team Operator** @ NOS
- **CTF Player** @ pwn_of_b4c4lh4u
- **Security Researcher** @ FutureSight



AGENDA

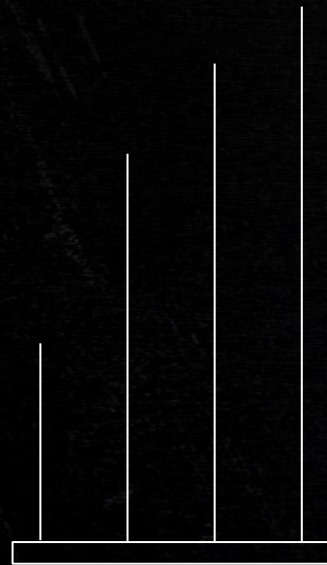


AGENDA

01

Introduction

Chrome? Never heard of her



AGENDA

01

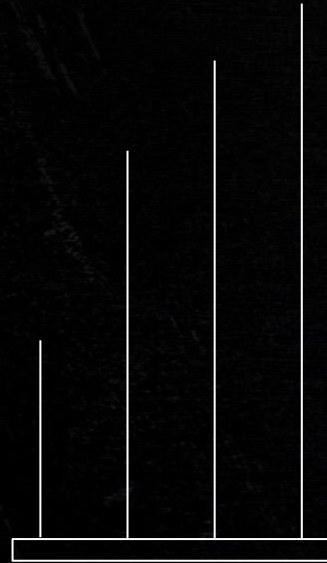
Introduction

Chrome? Never heard of her

02

Password Managers

How can we steal the creds



AGENDA

01

Introduction

Chrome? Never heard of her

03

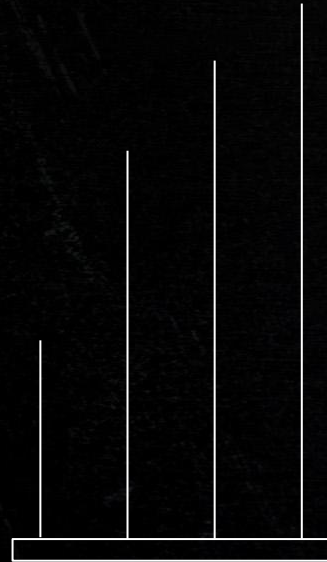
nativeMessaging

Wait you do what?

02

Password Managers

How can we steal the creds



AGENDA

01

Introduction

Chrome? Never heard of her

02

Password Managers

How can we steal the creds

03

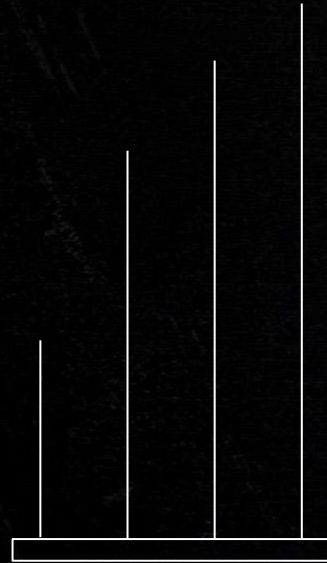
nativeMessaging

Wait you do what?

04

vscode Extensions

The middle child



01



INTRODUCTION



Chromium extensions and where to find them

Monopolies everywhere

○

●

●

●

Monopolies everywhere



Google Chrome



Monopolies everywhere



Google Chrome



Brave



Monopolies everywhere



Google Chrome



Brave



Vivaldi



Monopolies everywhere



Google Chrome



Brave



Vivaldi



Opera



Monopolies everywhere



Google Chrome



Brave



Vivaldi



Opera

Monopolies everywhere



Google Chrome



Brave



Vivaldi



Opera



Monopolies everywhere



Google Chrome



Brave



Vivaldi



Opera



Monopolies everywhere



Google Chrome



Brave



Vivaldi



Opera



Extending Chromium



Extending Chromium



01

Secure Preferences

Allows behaviour and appearance configuration
(if the dictator allows)

Extending Chromium



01

Secure Preferences

Allows behaviour and appearance configuration
(if the dictator allows)

02

Isolated Web Apps

Allows installing almost full
fledge apps under chrome
(what could go wrong)

Extending Chromium



01

Secure Preferences

Allows behaviour and appearance configuration
(if the dictator allows)

02

Isolated Web Apps

Allows installing almost full
fledge apps under chrome
(what could go wrong)

03

Extensions

Allows further addition of
features or functionality
(but limited by the manifest)

Ogres Extensions have layers...



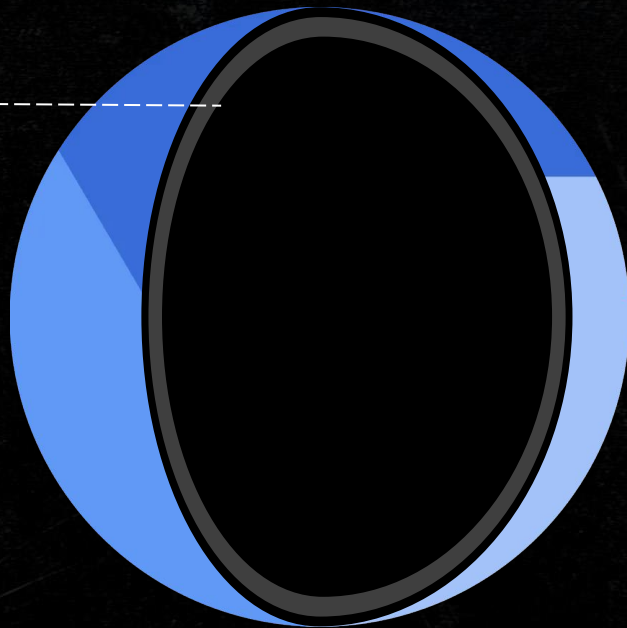
Ogres Extensions have layers...



Ogres Extensions have layers...

Package (zip)

Packing an extension generates a .crx and a .pem



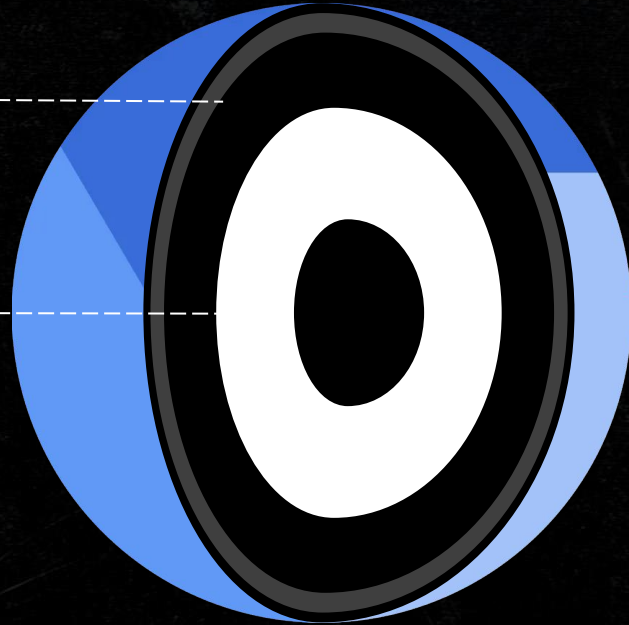
Ogres Extensions have layers...

Package (zip)

Packing an extension generates a .crx and a .pem

Manifest (.json)

Contains the extension metadata (name, icon, permissions...)



Ogres Extensions have layers...

Package (zip)

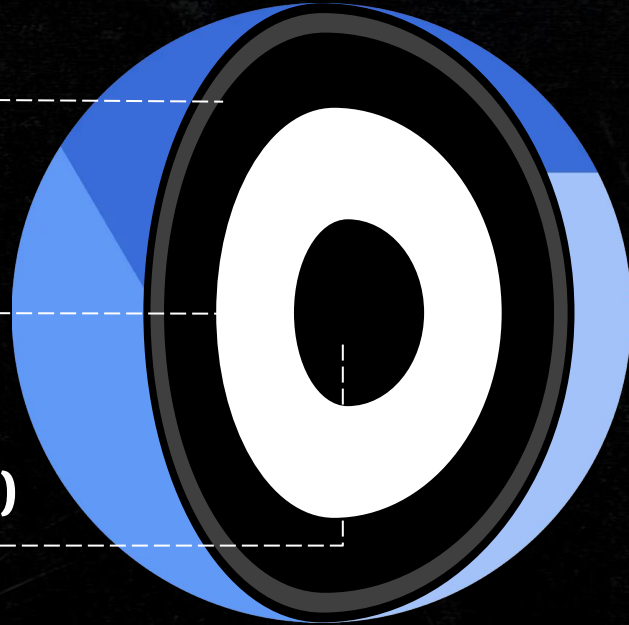
Packing an extension generates a .crx and a .pem

Manifest (.json)

Contains the extension metadata (name, icon, permissions...)

Content (js, html, wasm?)

Main extension functionality and UI



02

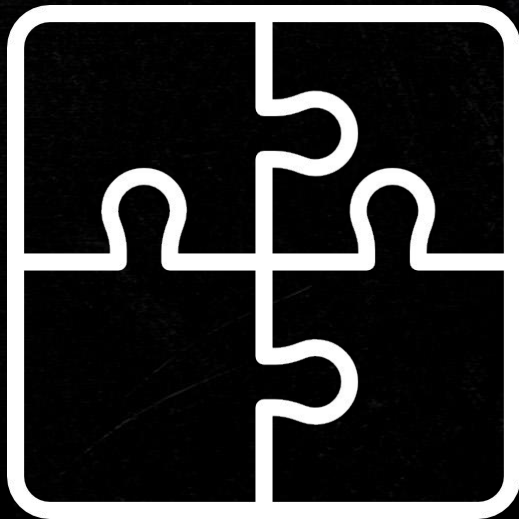
Password Managers



All the eggs in the same basket

Why not .txt?

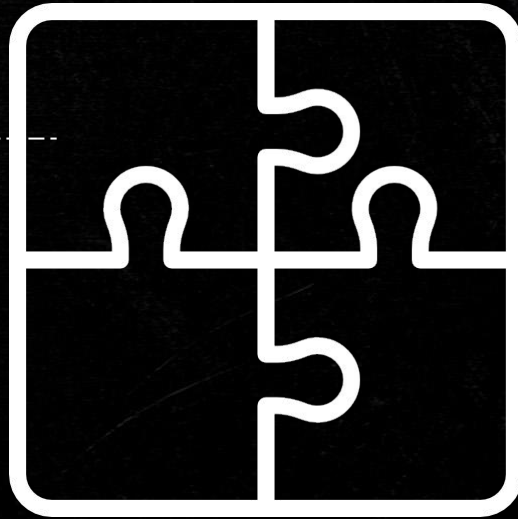
Why not .txt?



Why not .txt?

Masterkey

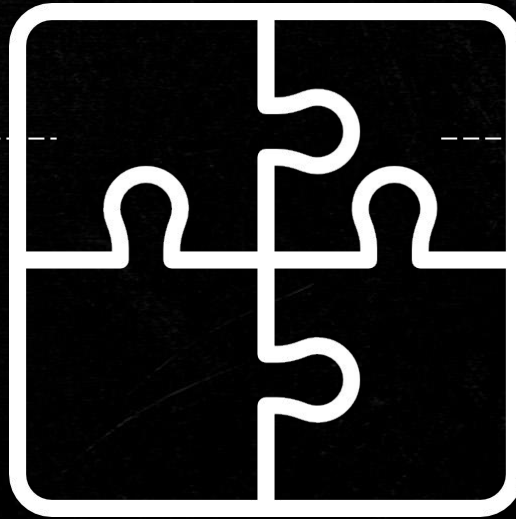
The user only needs to know the master key and can have MFA



Why not .txt?

Masterkey

The user only needs to know the master key and can have MFA



Password gen

The user can generate secure passwords binded to services

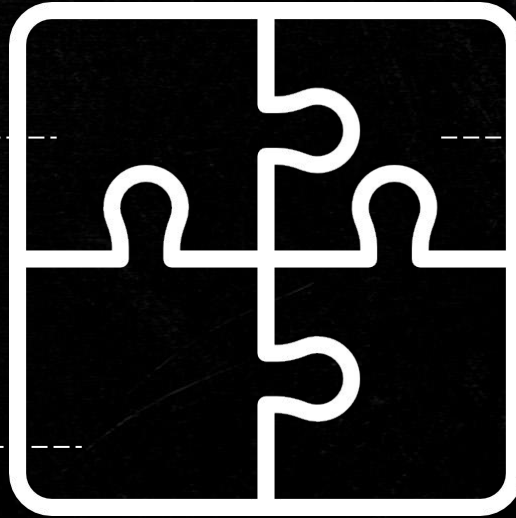
Why not .txt?

Masterkey

The user only needs to know the master key and can have MFA

MFA Builtin

The user can also have their MFA for the services inside the vault



Password gen

The user can generate secure passwords binded to services

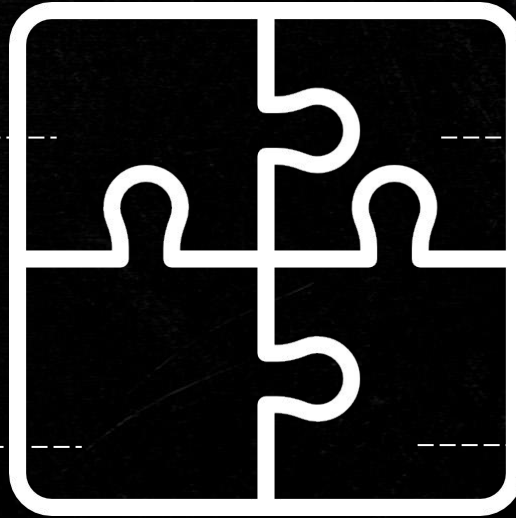
Why not .txt?

Masterkey

The user only needs to know the master key and can have MFA

MFA Builtin

The user can also have their MFA for the services inside the vault



Password gen

The user can generate secure passwords binded to services

Multiclient

Multiple clients to access the vault, either native or as a **browser extension**

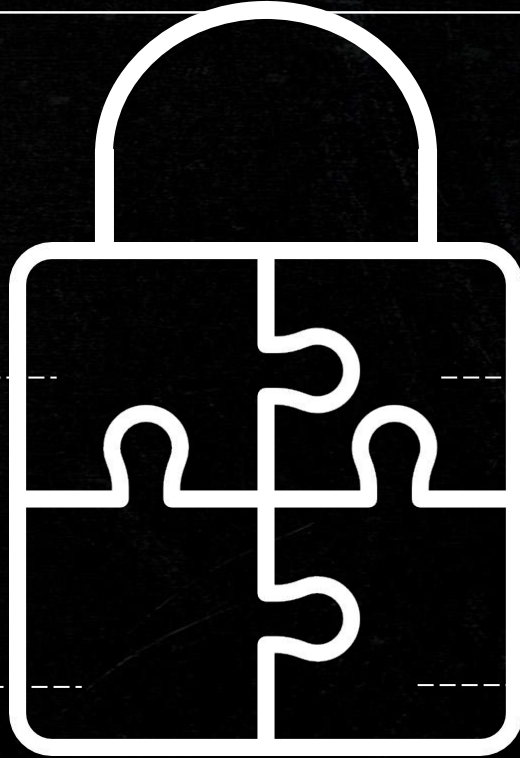
Why not .txt?

Masterkey

The user only needs to know the master key and can have MFA

MFA Builtin

The user can also have their MFA for the services inside the vault



Password gen

The user can generate secure passwords binded to services

Multiclient

Multiple clients to access the vault, either native or as a **browser extension**

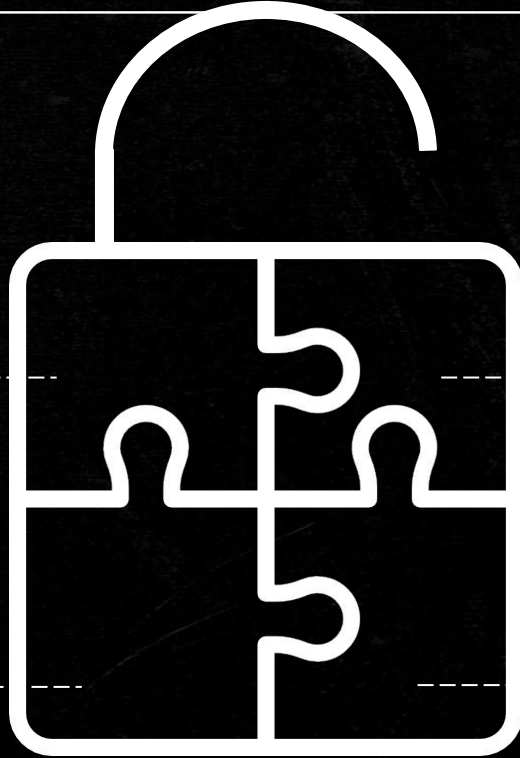
Why not .txt?

Masterkey

The user only needs to know the master key and can have MFA

MFA Builtin

The user can also have their MFA for the services inside the vault



Password gen

The user can generate secure passwords binded to services

Multiclient

Multiple clients to access the vault, either native or as a **browser extension**

SIGNIFICANT EVENTS



SIGNIFICANT EVENTS



01

Open

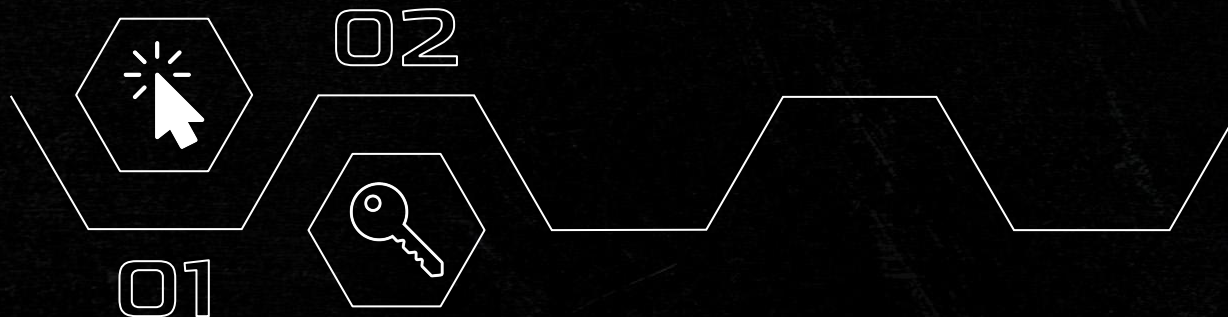
User opens extension

SIGNIFICANT EVENTS



Extension requests
masterkey

Gib key



01
Open

User opens extension

SIGNIFICANT EVENTS

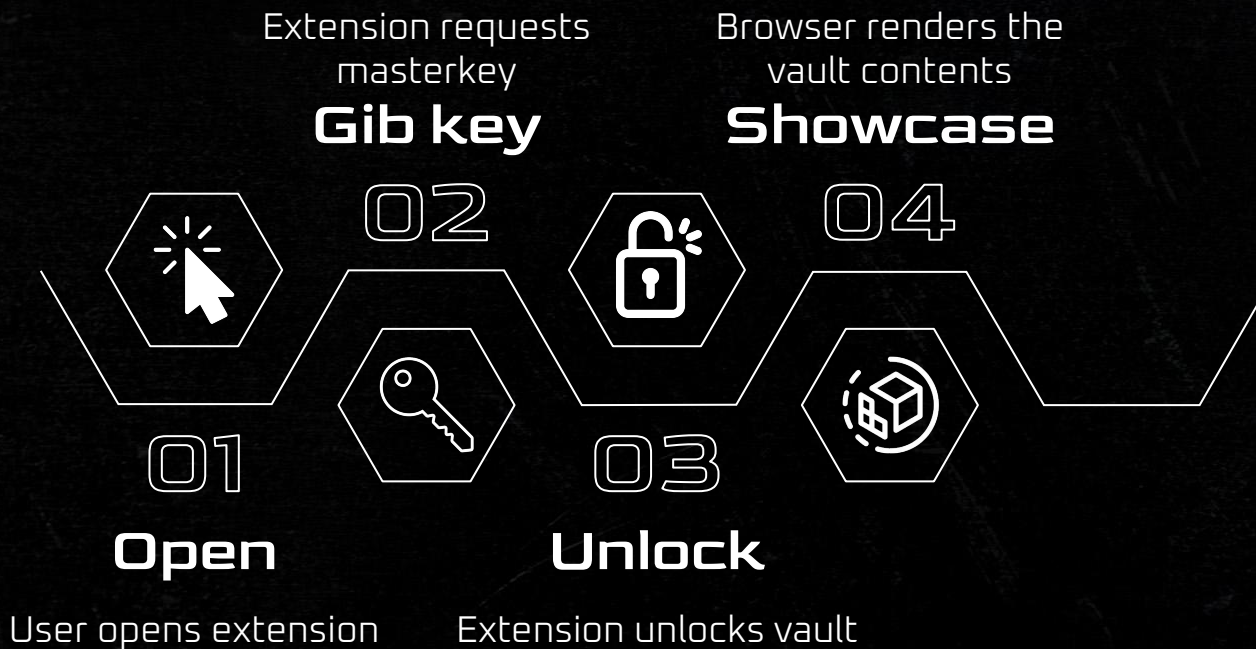


Extension requests
masterkey

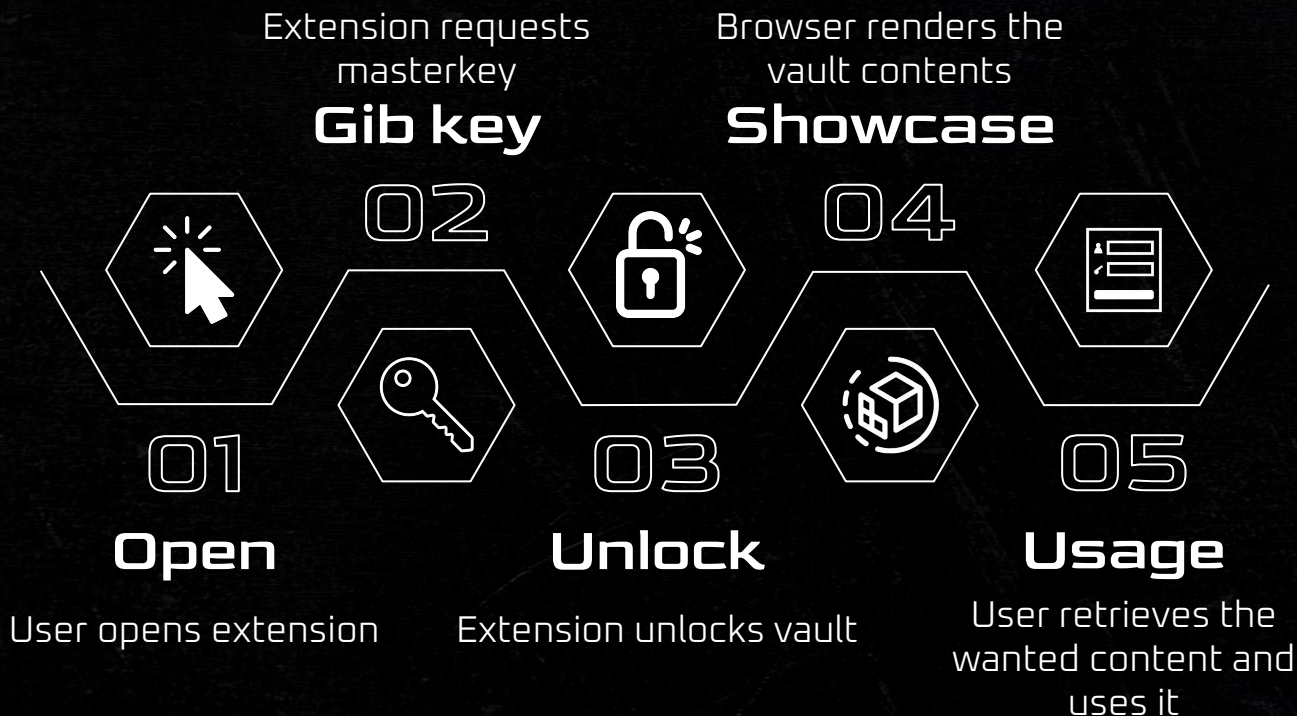
Gib key



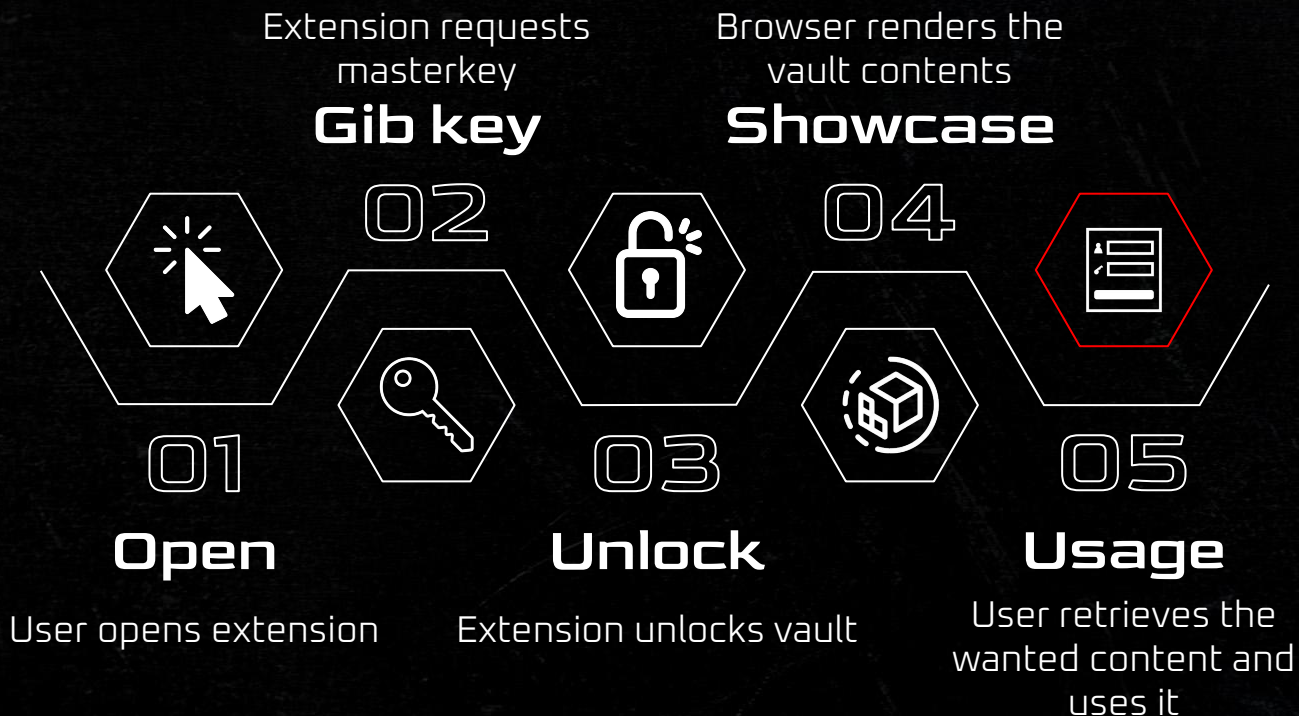
SIGNIFICANT EVENTS



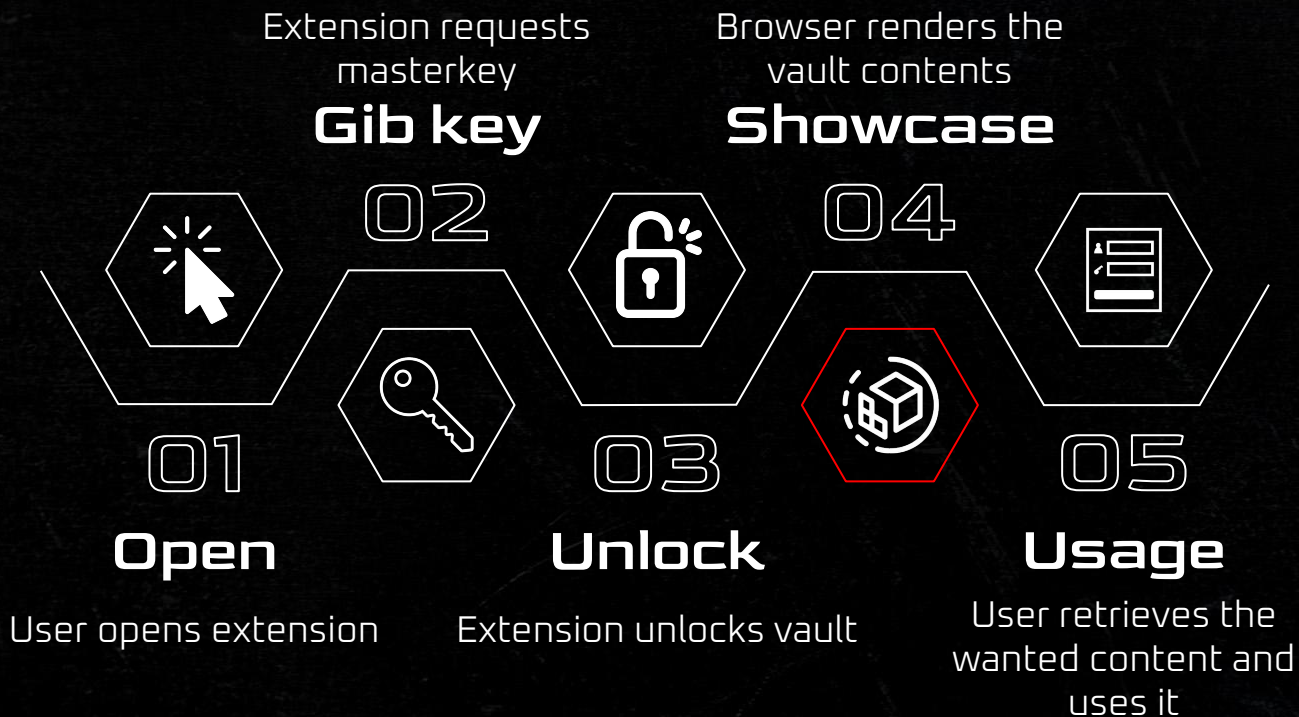
SIGNIFICANT EVENTS



SIGNIFICANT EVENTS



SIGNIFICANT EVENTS



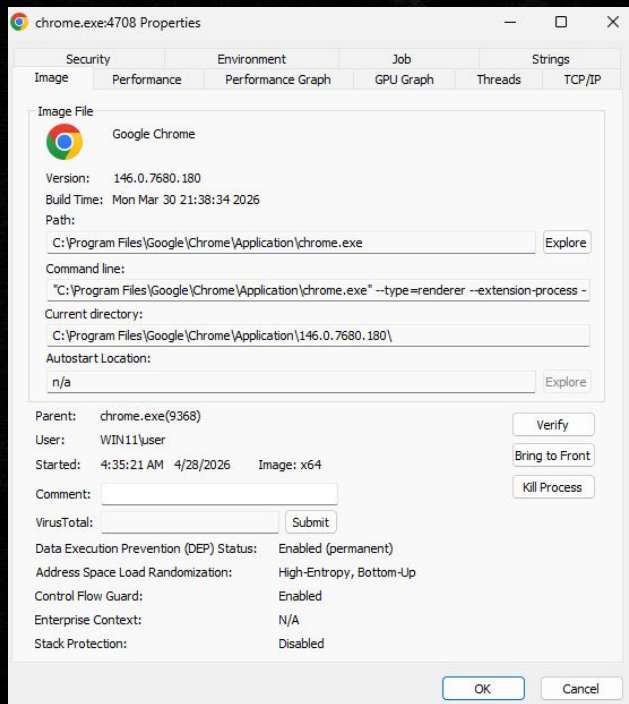
Why the renderer

Process	CPU	Private Bytes	Working Set	PID	Description	Company Name
 chrome.exe	< 0.01	64,812 K	189,924 K	9368	Google Chrome	Google LLC
 chrome.exe		2,400 K	9,260 K	4748	Google Chrome	Google LLC
 chrome.exe		27,080 K	74,908 K	4520	Google Chrome	Google LLC
 chrome.exe		13,464 K	39,612 K	4648	Google Chrome	Google LLC
 chrome.exe		9,444 K	19,024 K	4204	Google Chrome	Google LLC
 chrome.exe		22,424 K	63,800 K	5532	Google Chrome	Google LLC
 chrome.exe		38,688 K	88,248 K	5112	Google Chrome	Google LLC
 chrome.exe		15,264 K	28,868 K	10140	Google Chrome	Google LLC

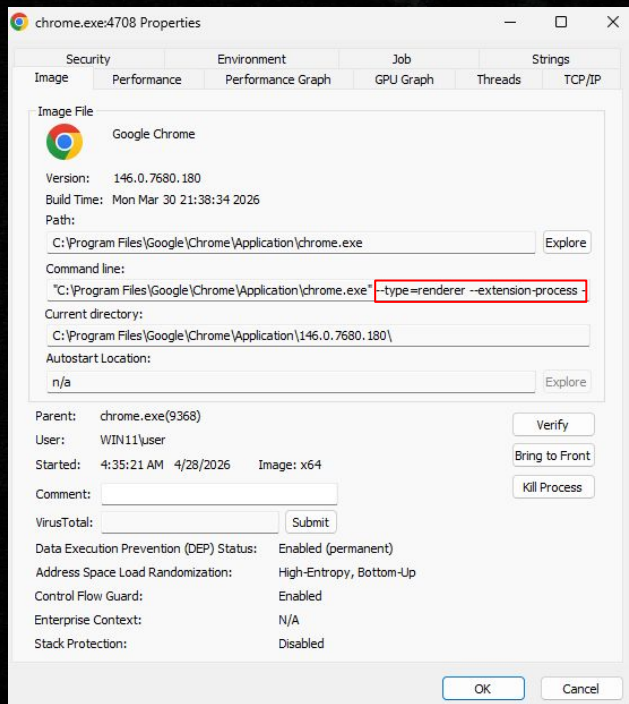
Why the renderer

Process	CPU	Private Bytes	Working Set	PID	Command Line
 chrome.exe	< 0.01	63,012 K	189,324 K	9368	"C:\Program Files\Google\Chrome\Application\chrome.exe"
 chrome.exe		2,332 K	9,248 K	4748	"C:\Program Files\Google\Chrome\Application\chrome.exe" -type=crashpad-handler "-user-data-dir=C:\Users\u...
 chrome.exe		26,600 K	74,888 K	4520	"C:\Program Files\Google\Chrome\Application\chrome.exe" -type=gpu-process -no-pre-read-main-dll -gpu-prefe...
 chrome.exe		12,824 K	39,476 K	4648	"C:\Program Files\Google\Chrome\Application\chrome.exe" -type=utility -utility-sub-type=network.mojom.Network...
 chrome.exe		9,188 K	18,996 K	4204	"C:\Program Files\Google\Chrome\Application\chrome.exe" -type=utility -utility-sub-type=storage.mojom.Storage...
 chrome.exe	< 0.01	21,608 K	62,384 K	5532	"C:\Program Files\Google\Chrome\Application\chrome.exe" -type=renderer --video-capture-use-gpu-memory-buff...
 chrome.exe		36,144 K	85,696 K	5112	"C:\Program Files\Google\Chrome\Application\chrome.exe" -type=renderer --video-capture-use-gpu-memory-buff...
 chrome.exe		15,236 K	29,008 K	10140	"C:\Program Files\Google\Chrome\Application\chrome.exe" -type=renderer --disable-gpu-compositing --video-ca...

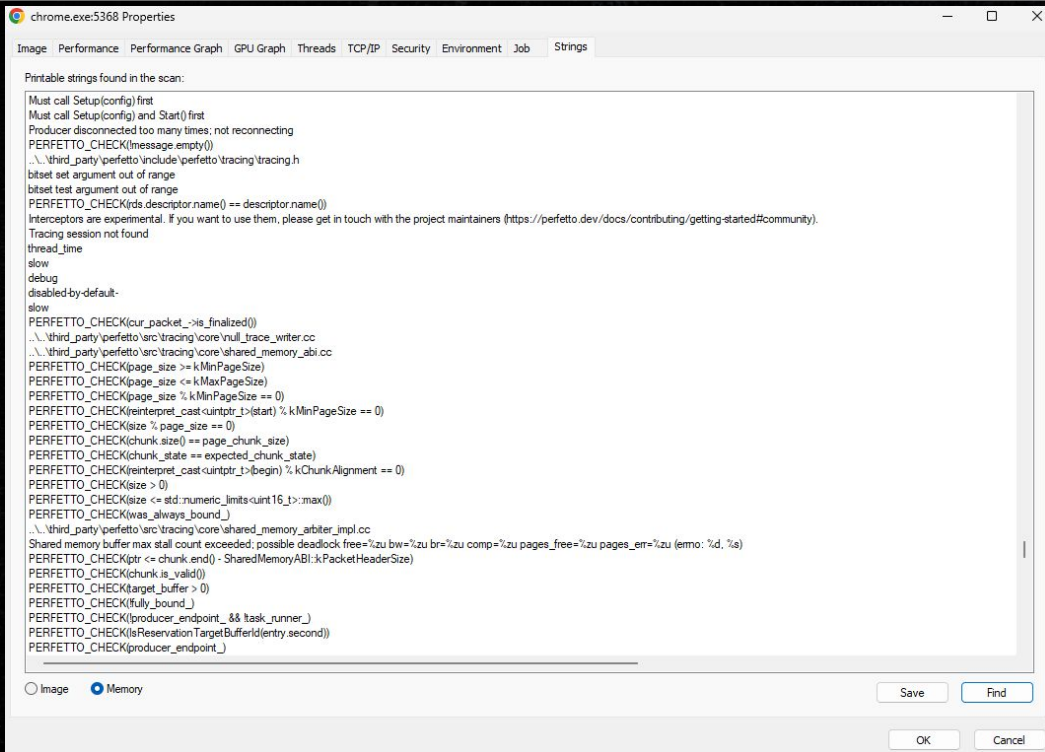
Why the renderer



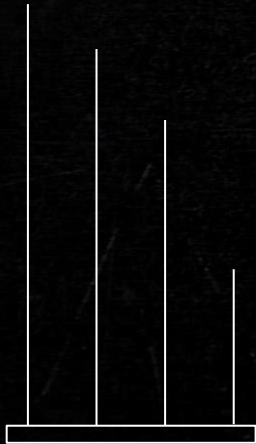
Why the renderer



Why the renderer



DEMO TIME



03 

nativeMessaging



Let me talk to your host

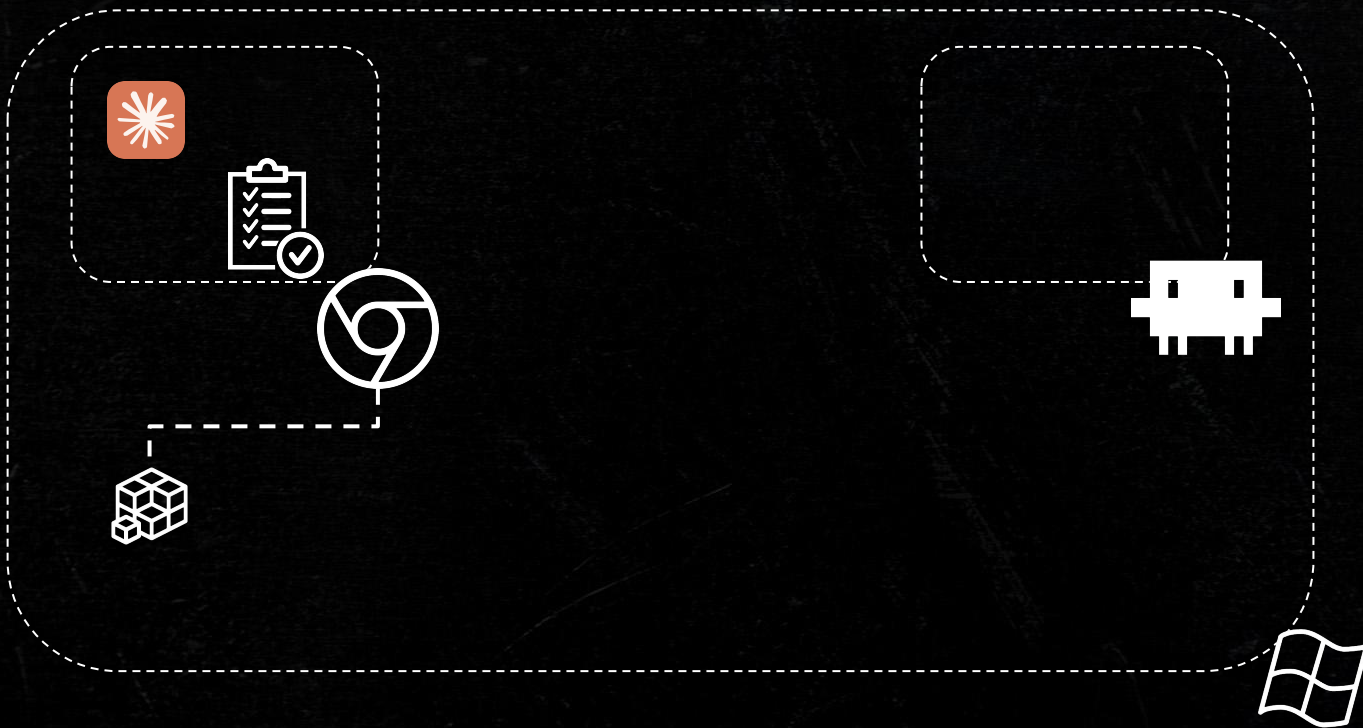
Beepboop run exe



Beepboop run exe



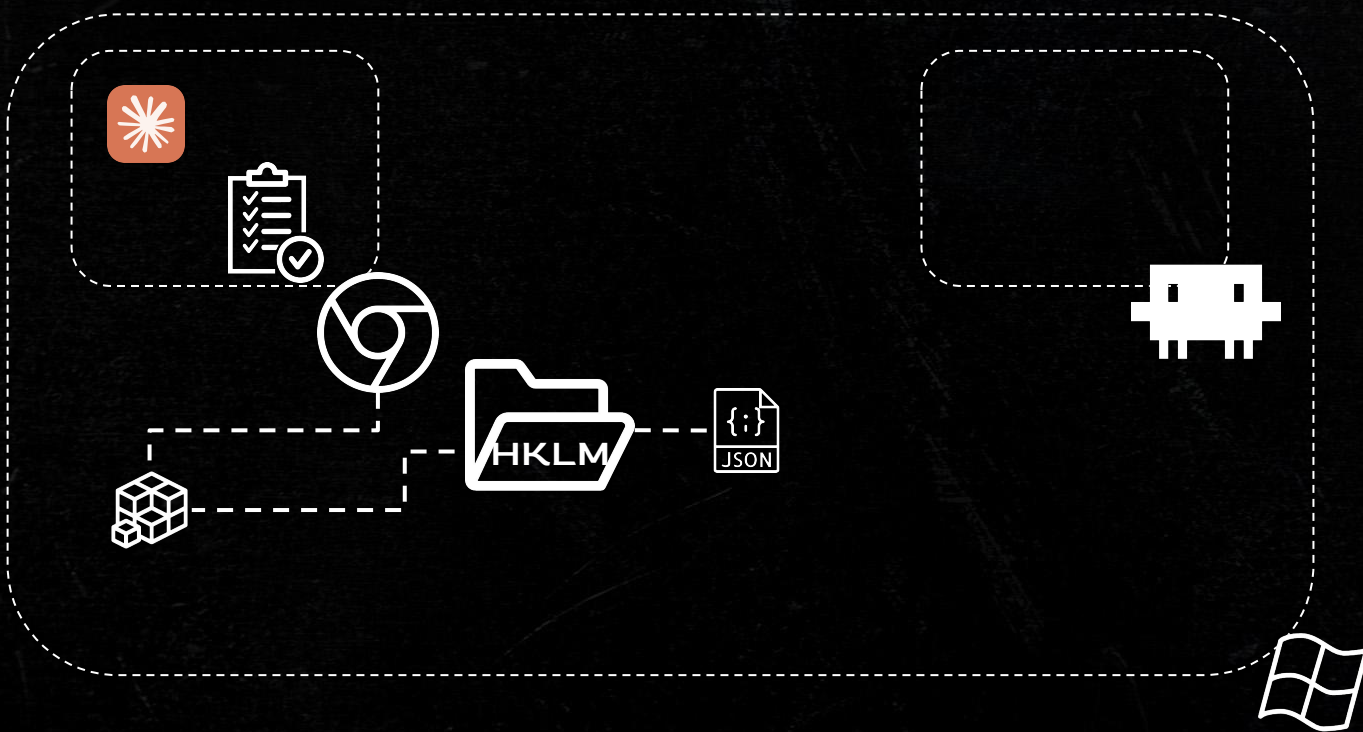
Beepboop run exe



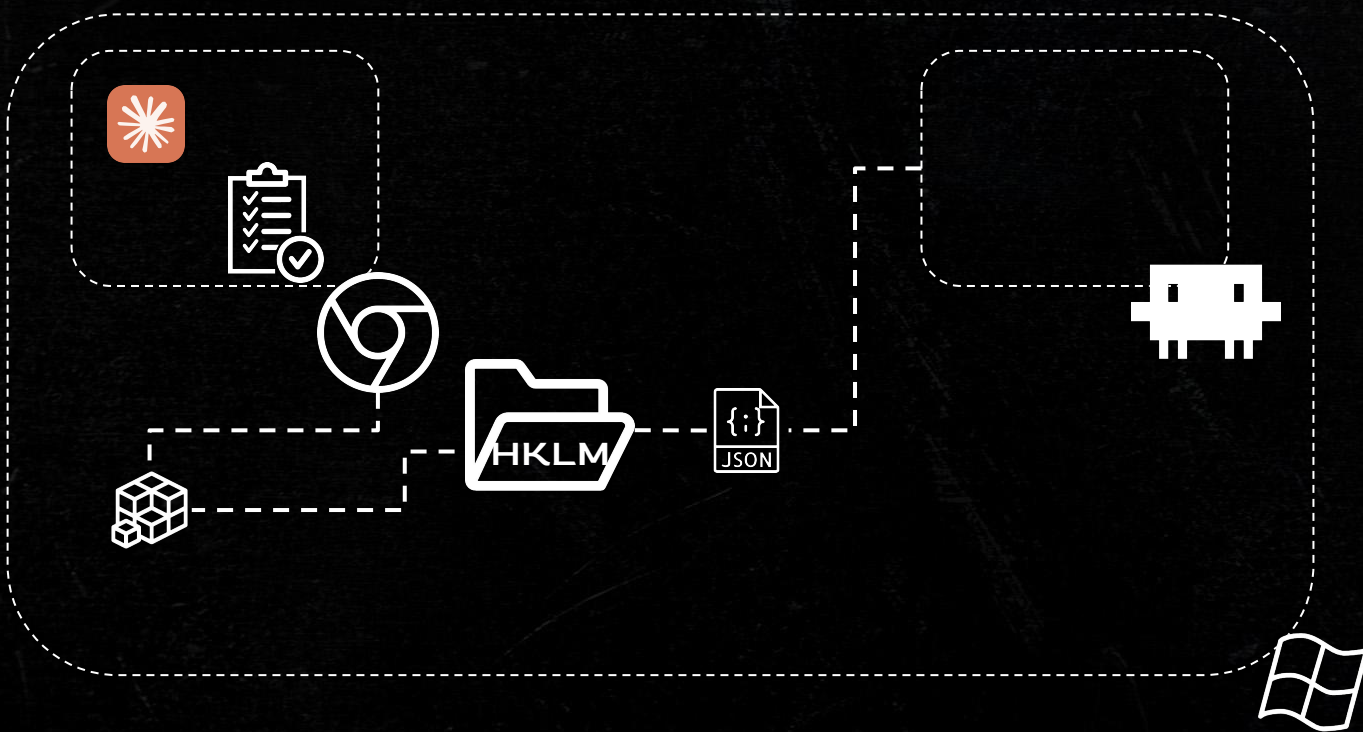
Beepboop run exe



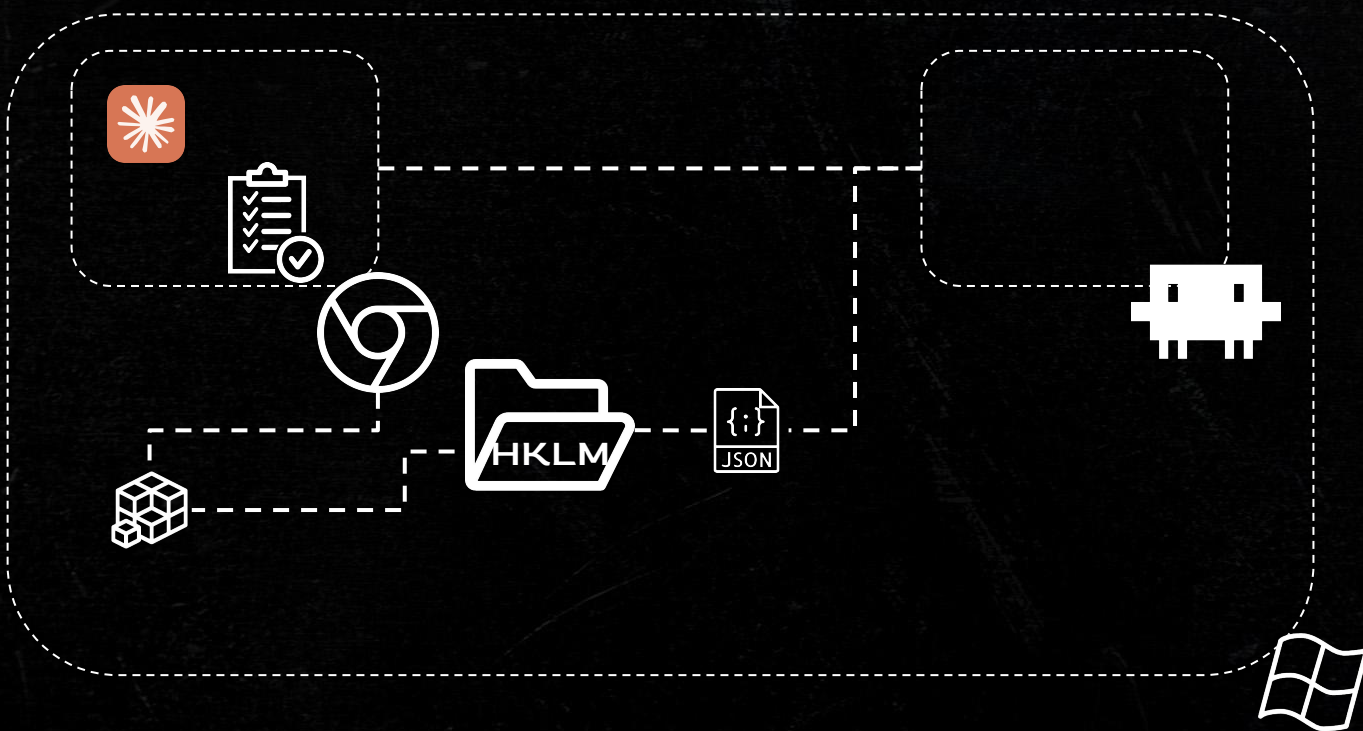
Beepboop run exe



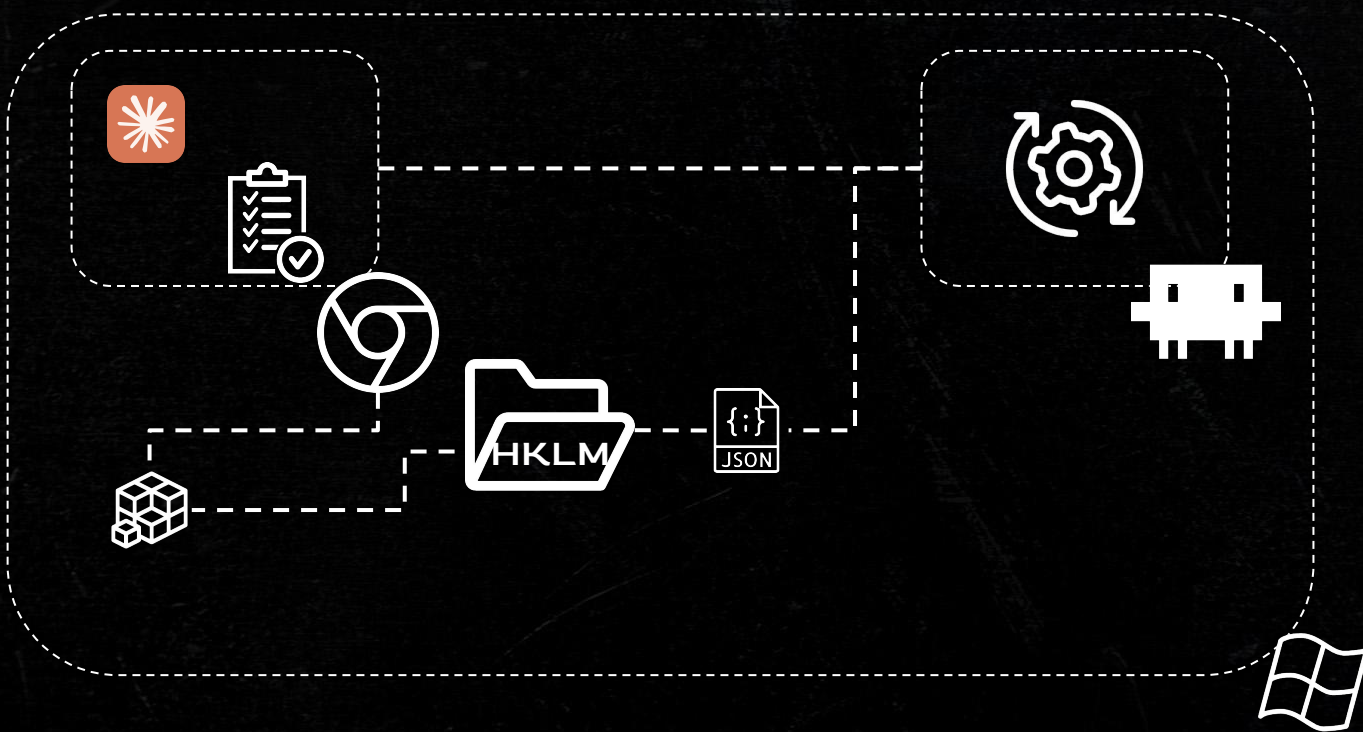
Beepboop run exe



Beepboop run exe



Beepboop run exe



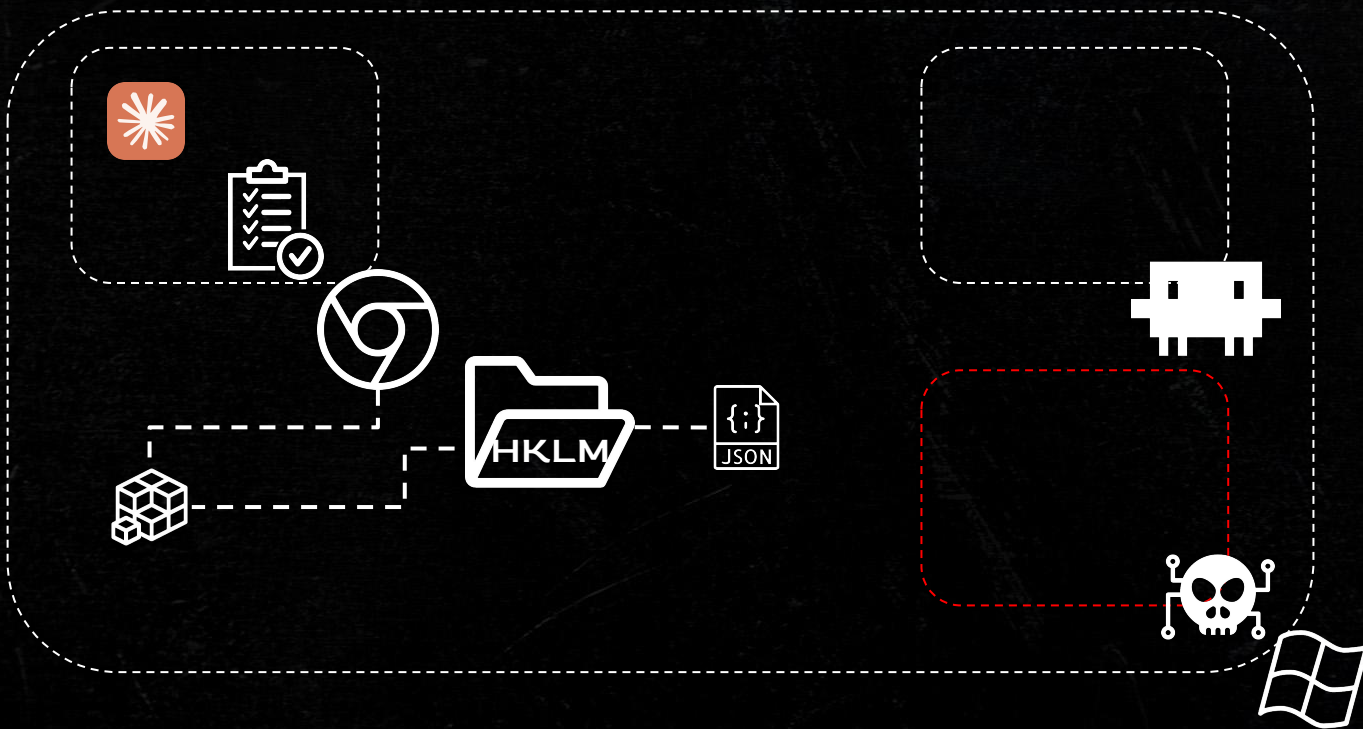
Beepboop run exe



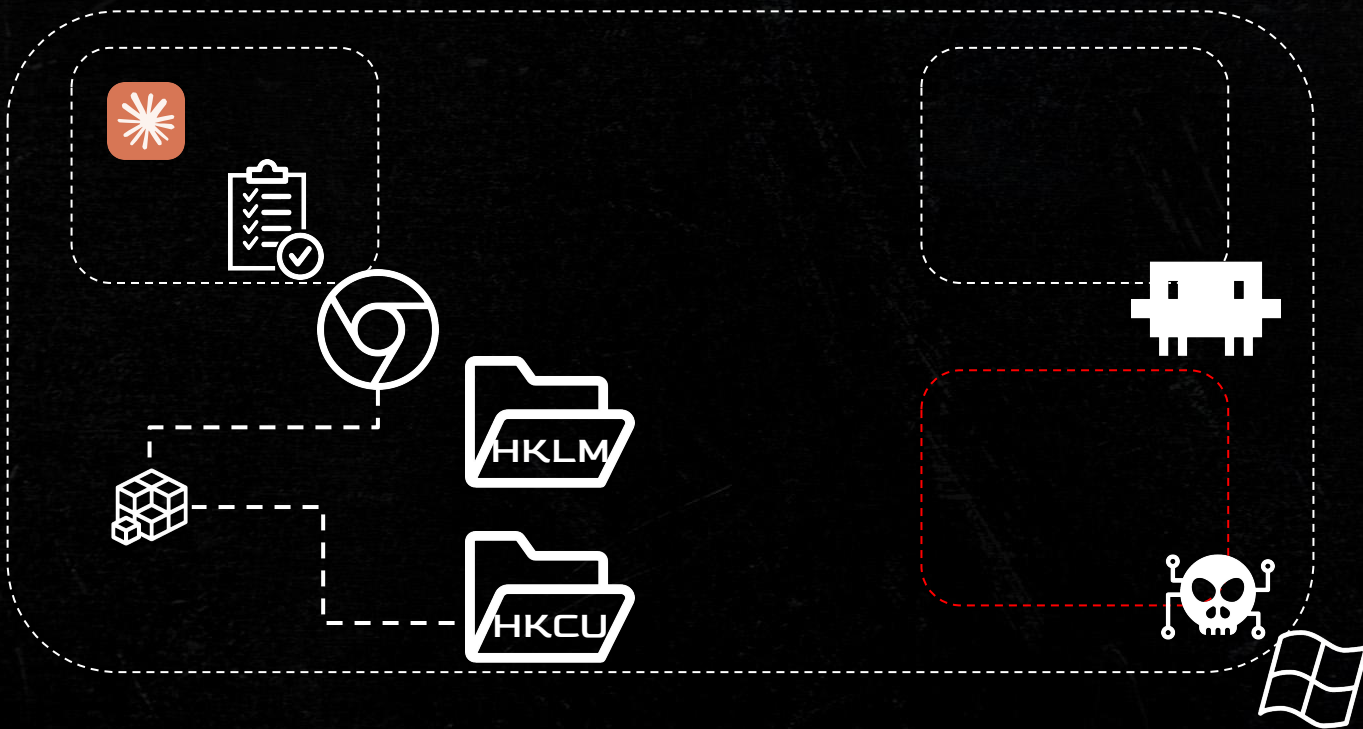
Beepboop run exe



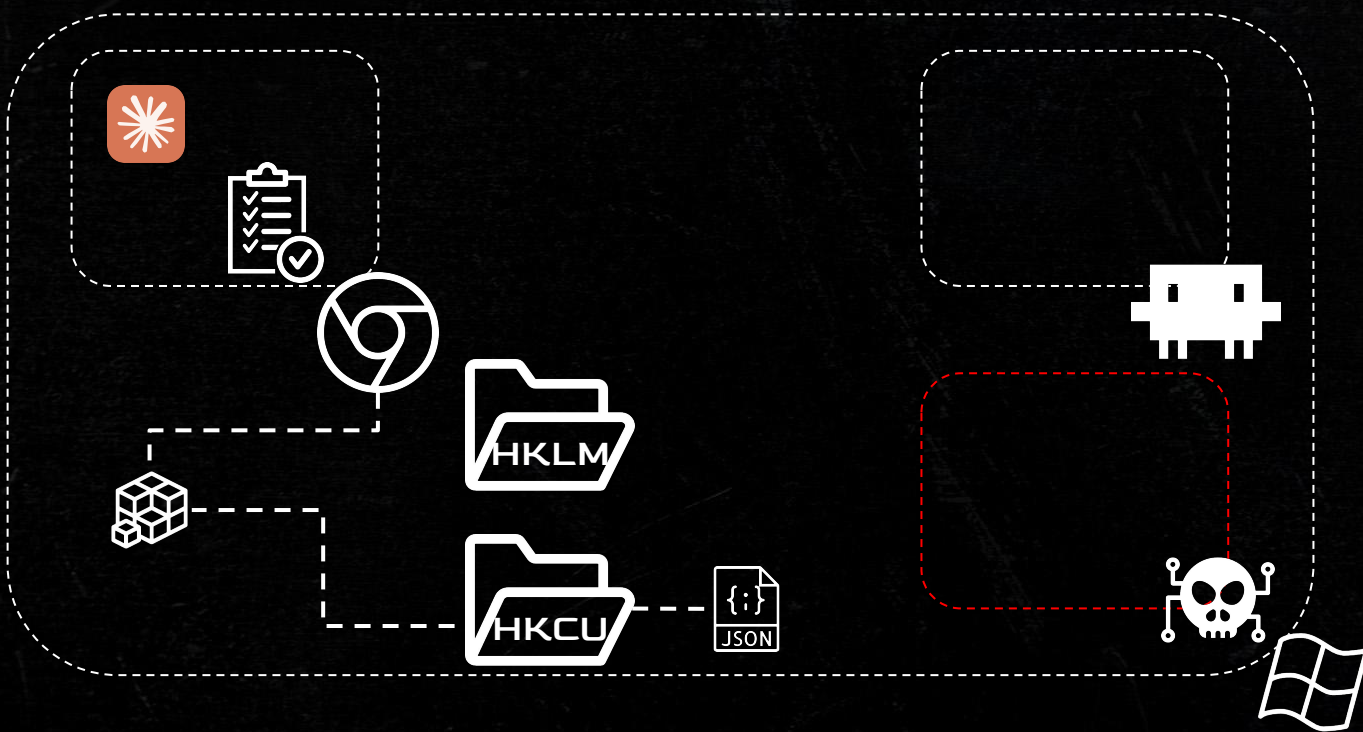
Beepboop run exe



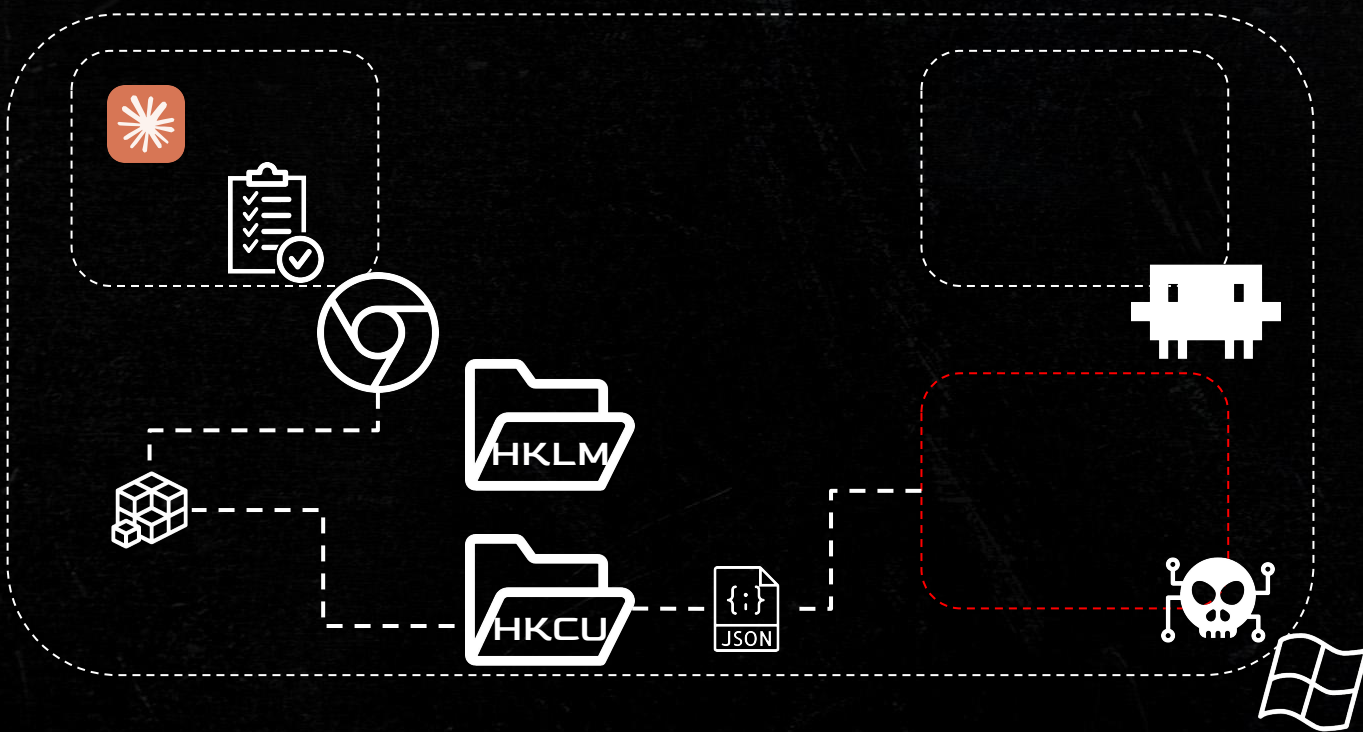
Beepboop run exe

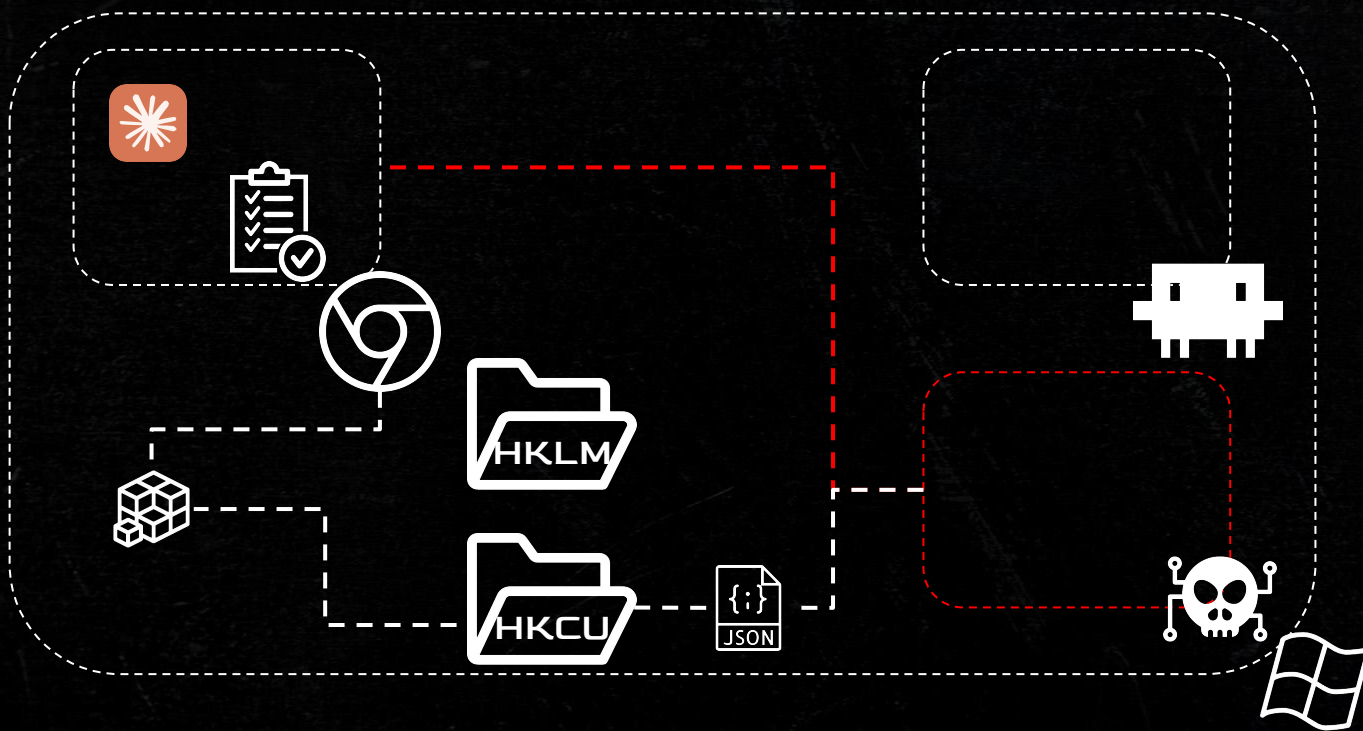


Beepboop run exe

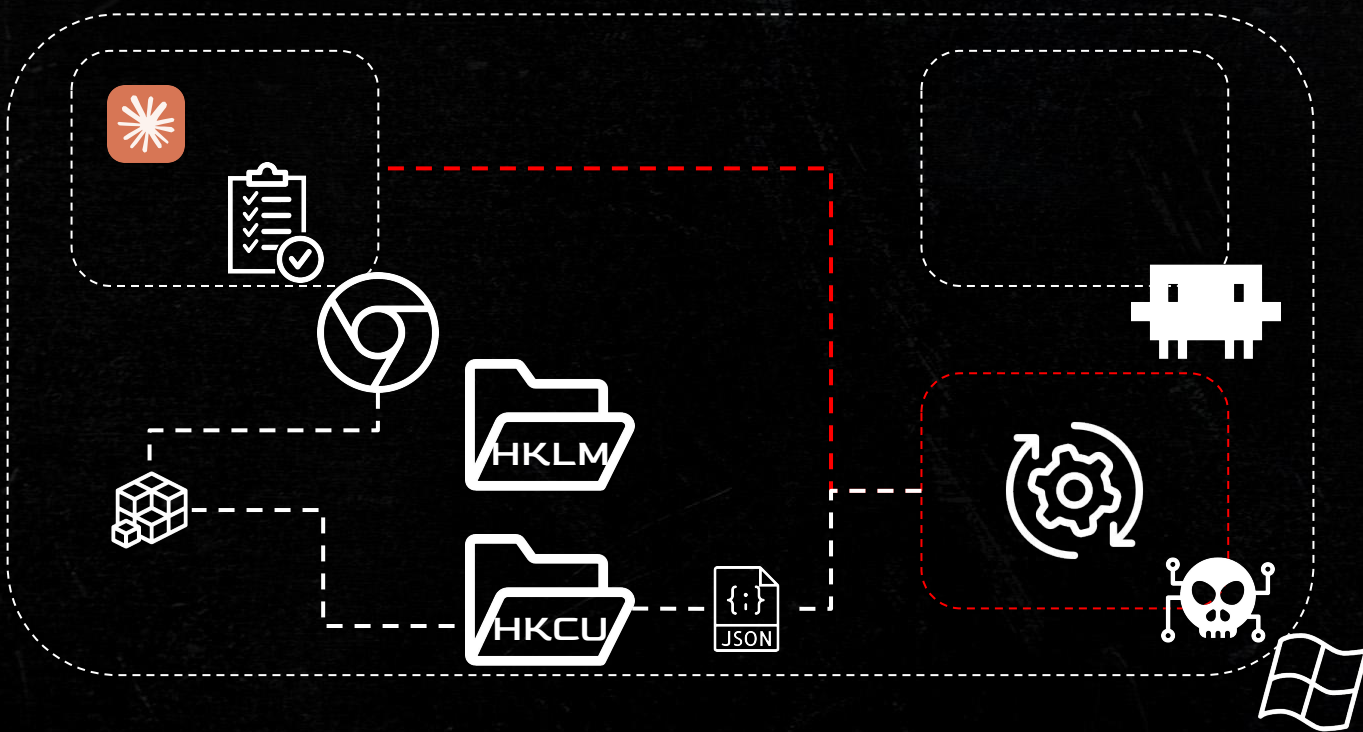


Beepboop run exe

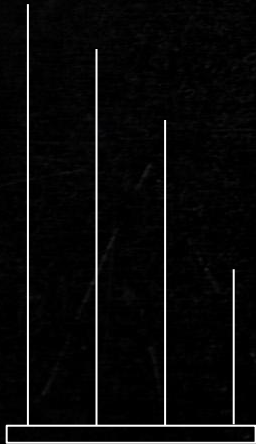




Beepboop run exe



DEMO TIME



04



vscode Extensions



Developers, developers, developers, developers...

Extension lifecycle



Extension lifecycle



01

Download

Chromium downloads

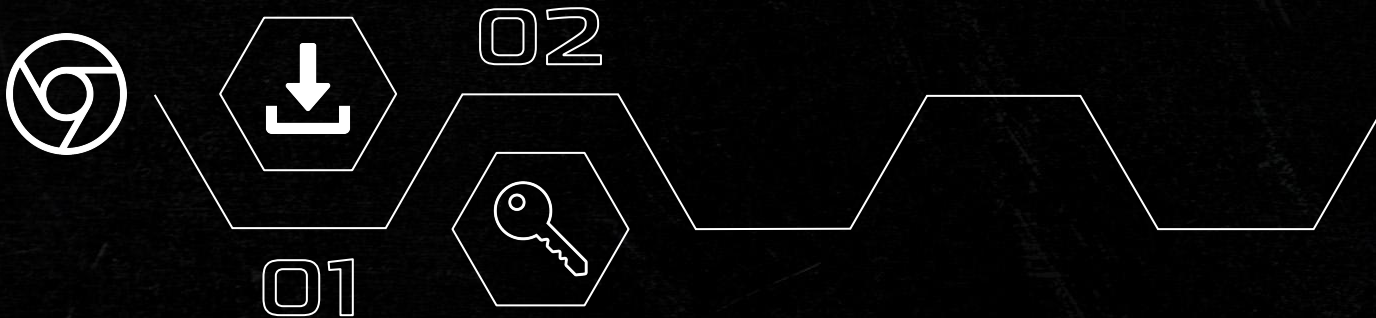
.crx

Extension lifecycle



Extension signature is
checked against web DB

Sig check



Download

Chromium downloads
.crx

Extension lifecycle

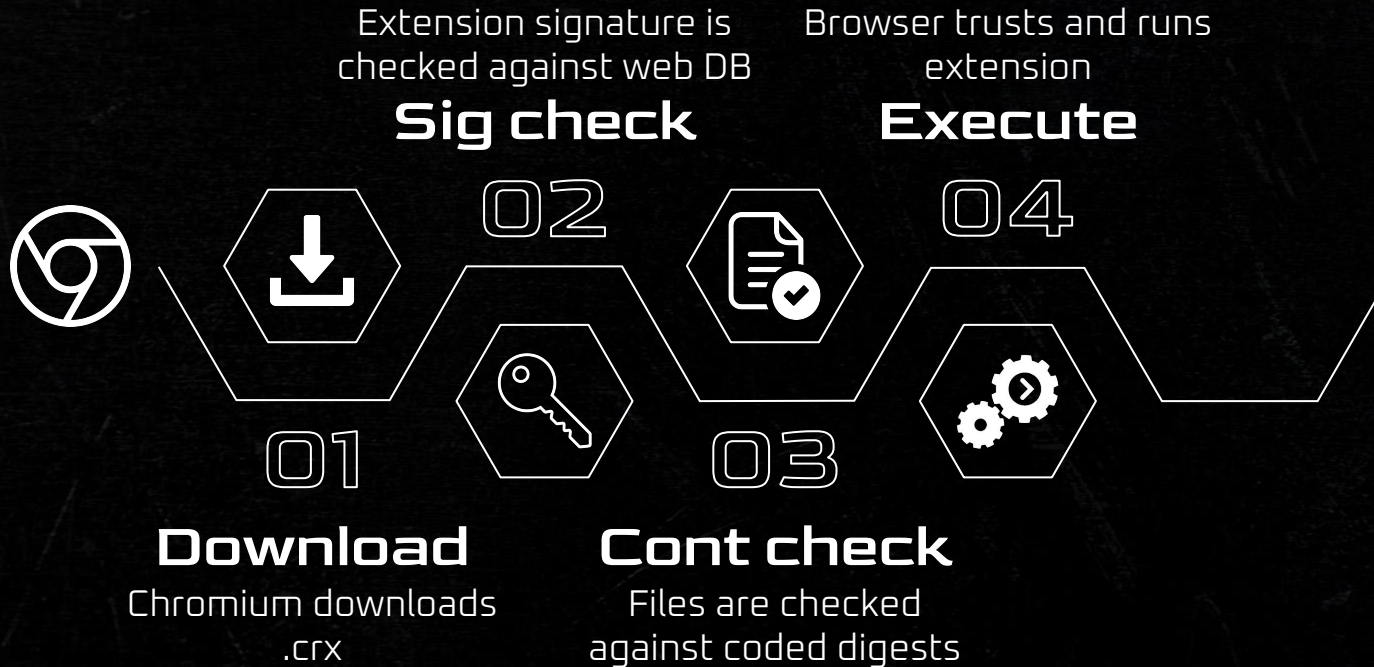


Extension signature is
checked against web DB

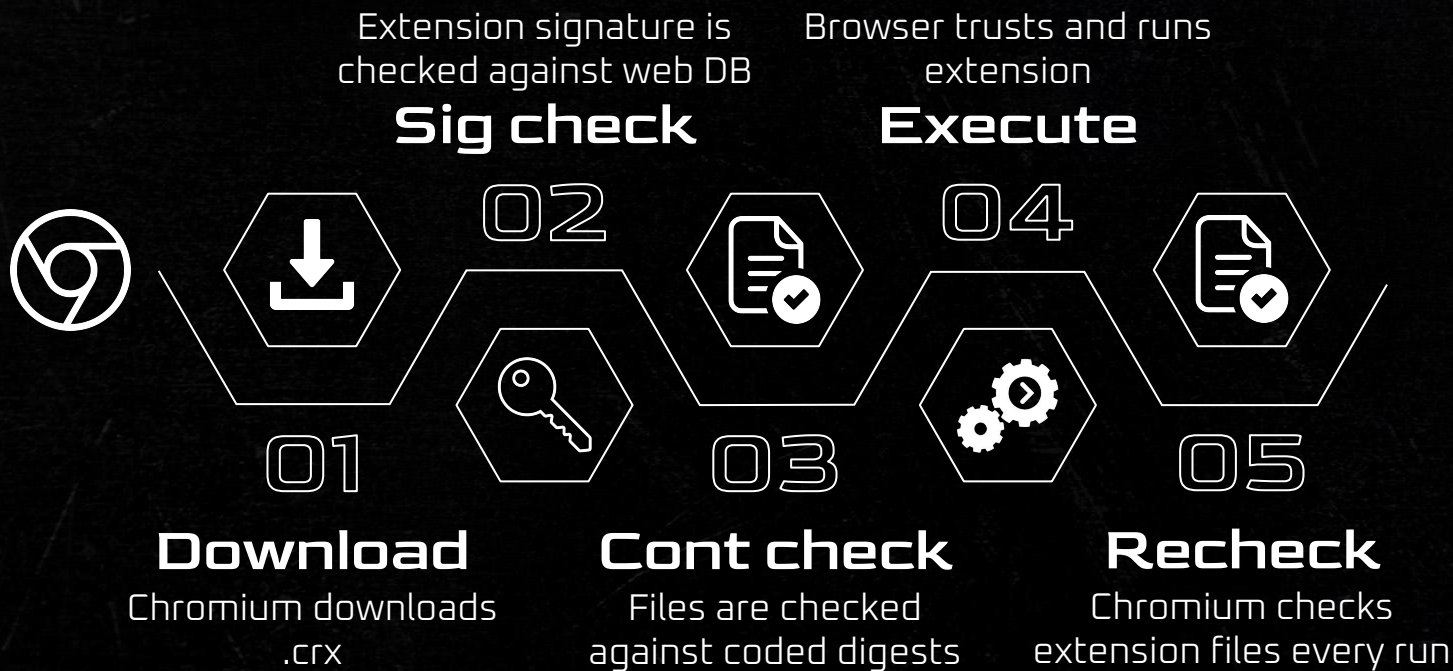
Sig check



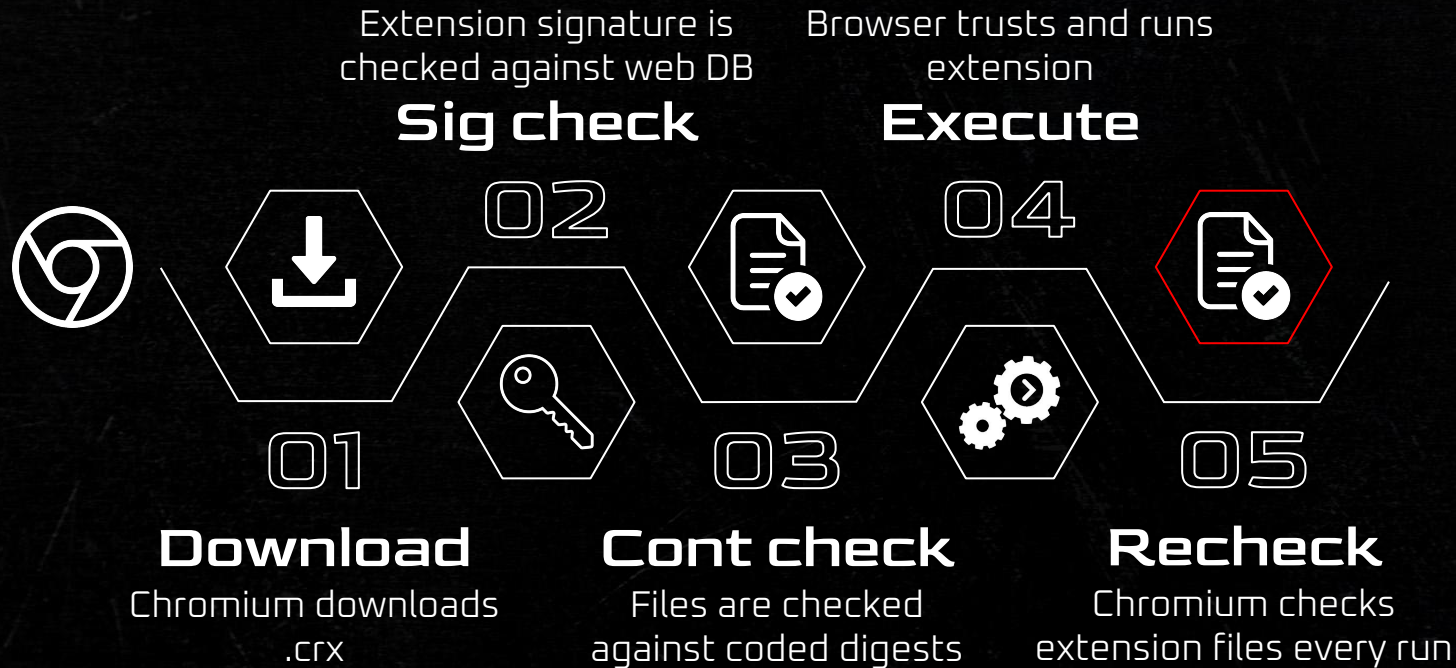
Extension lifecycle



Extension lifecycle



Extension lifecycle



Extension lifecycle



Extension lifecycle



01

Download

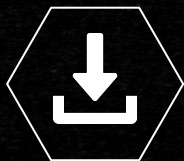
Chromium downloads
.vsix

Extension lifecycle



Extension signature is
checked against registry

Sig check



02



01

Download

Chromium downloads
.vsix

Extension lifecycle

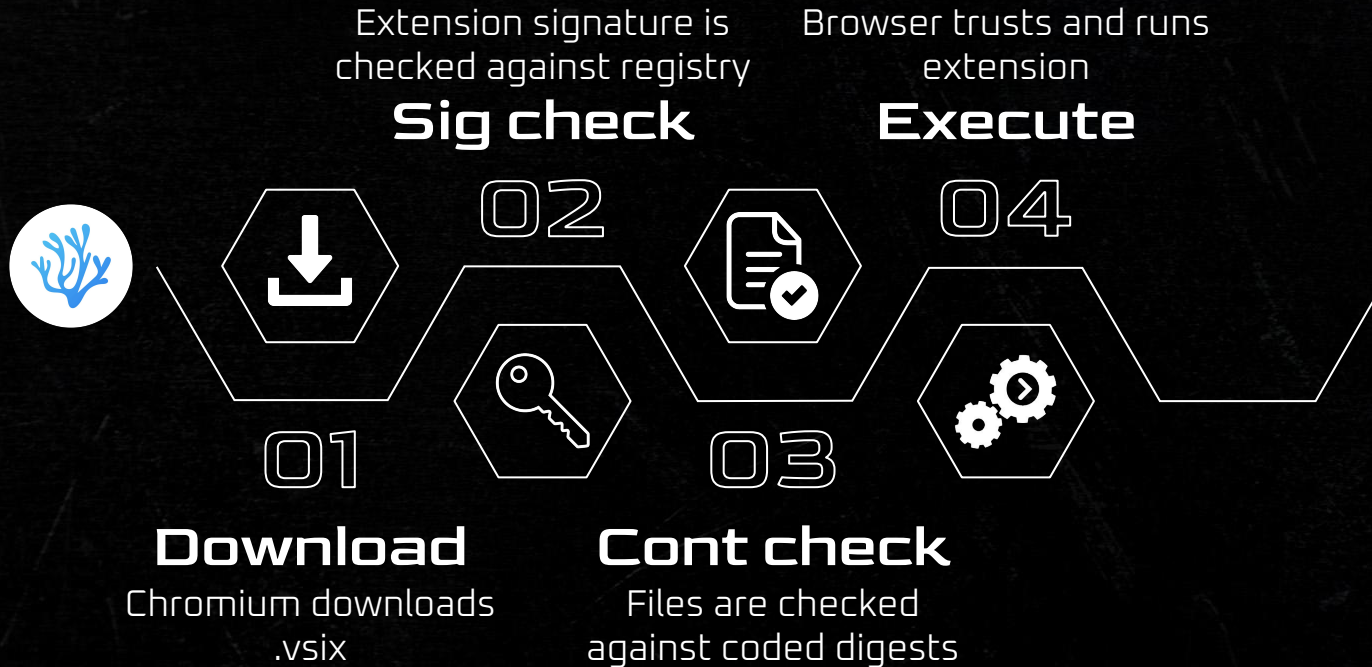


Extension signature is
checked against registry

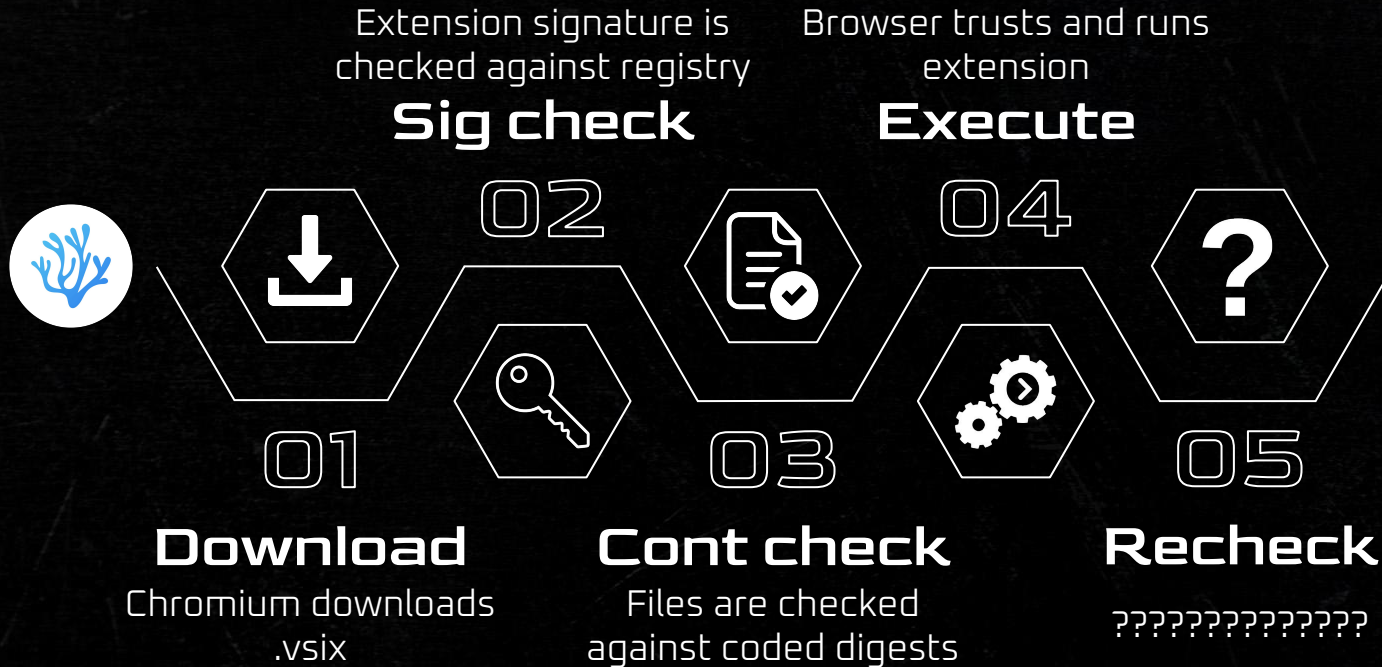
Sig check



Extension lifecycle



Extension lifecycle



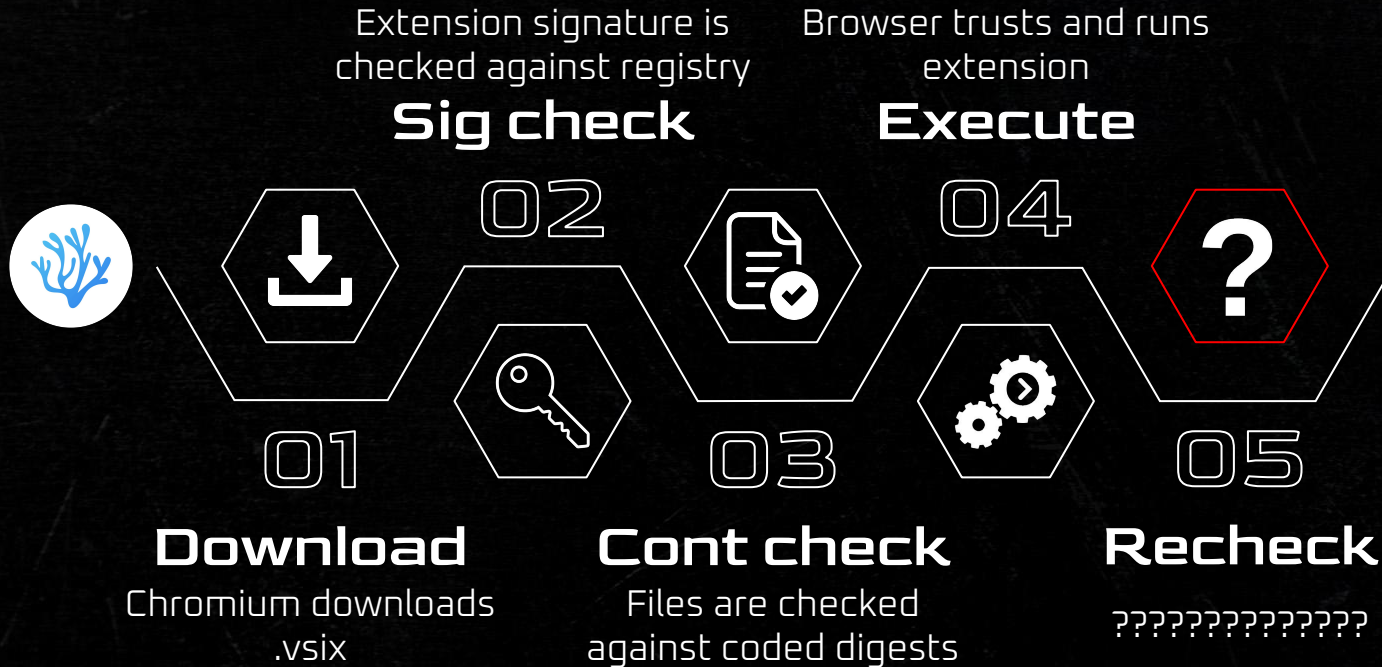
Checking the checker



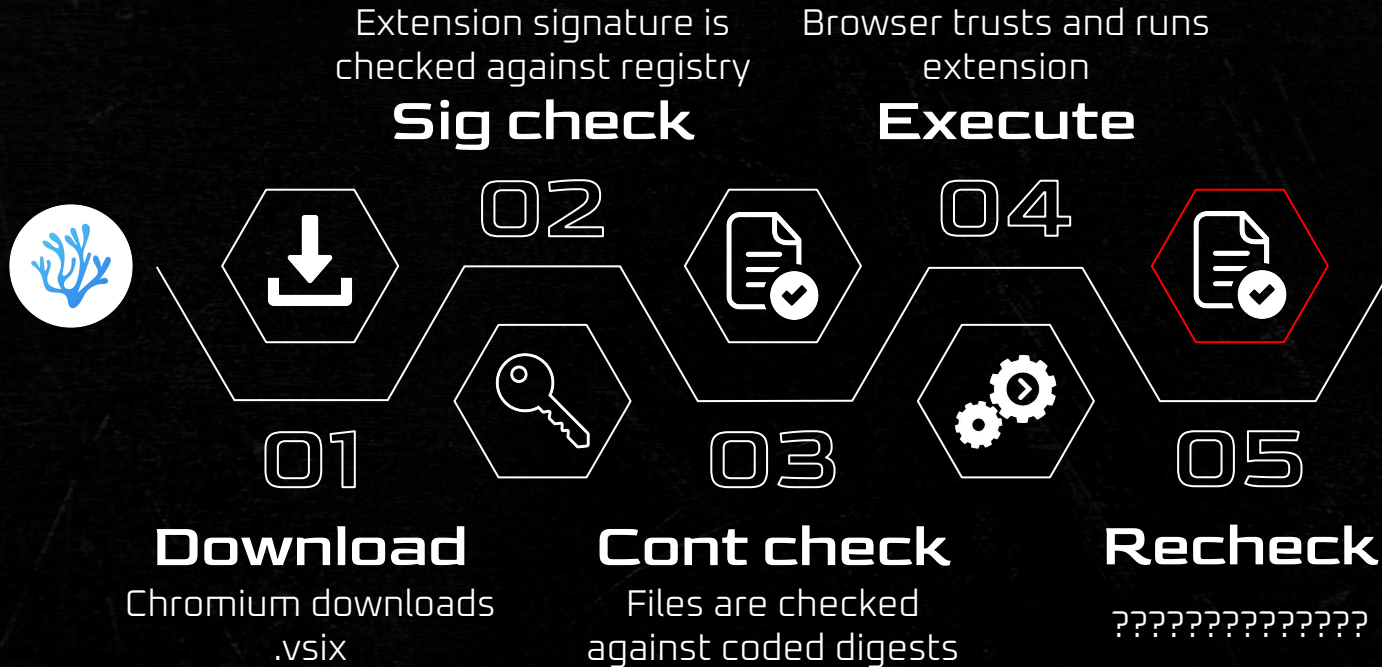
⊗ Extensions have been modified on disk. Please reload the window. ✕

Reload Window

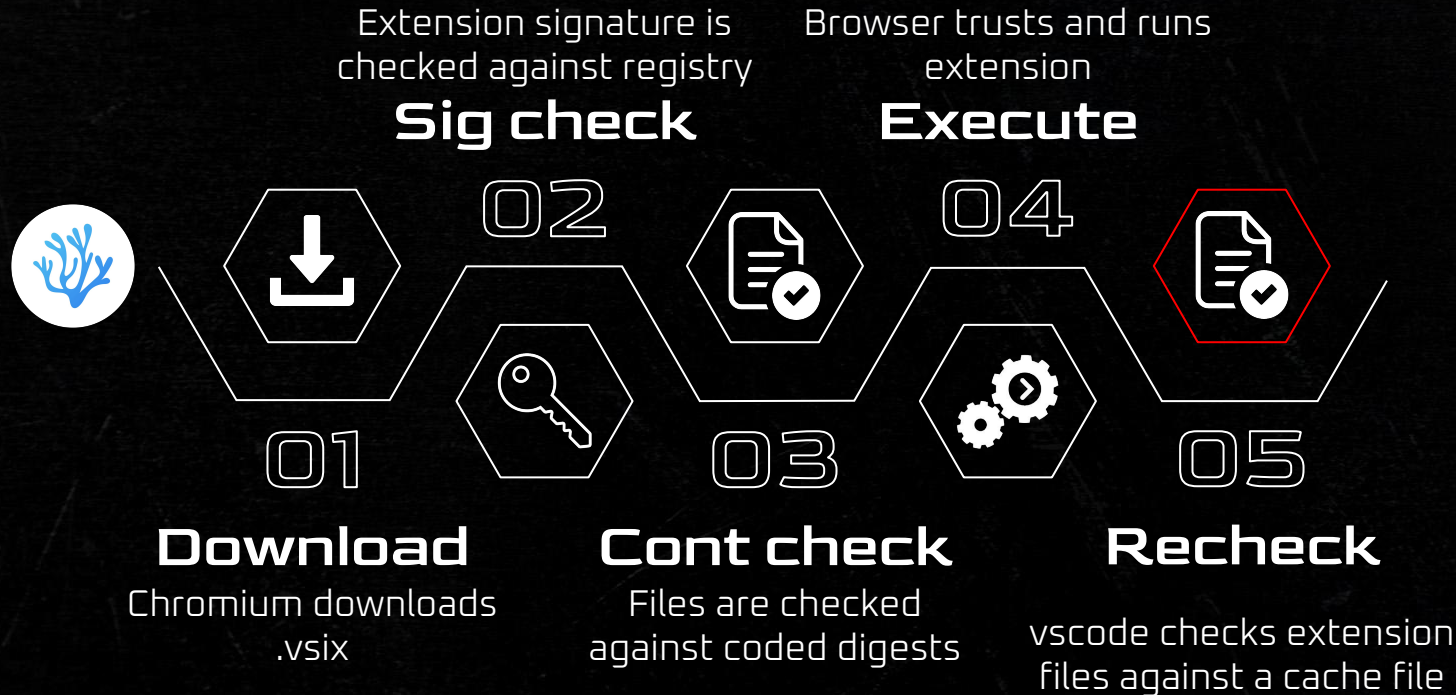
Extension lifecycle



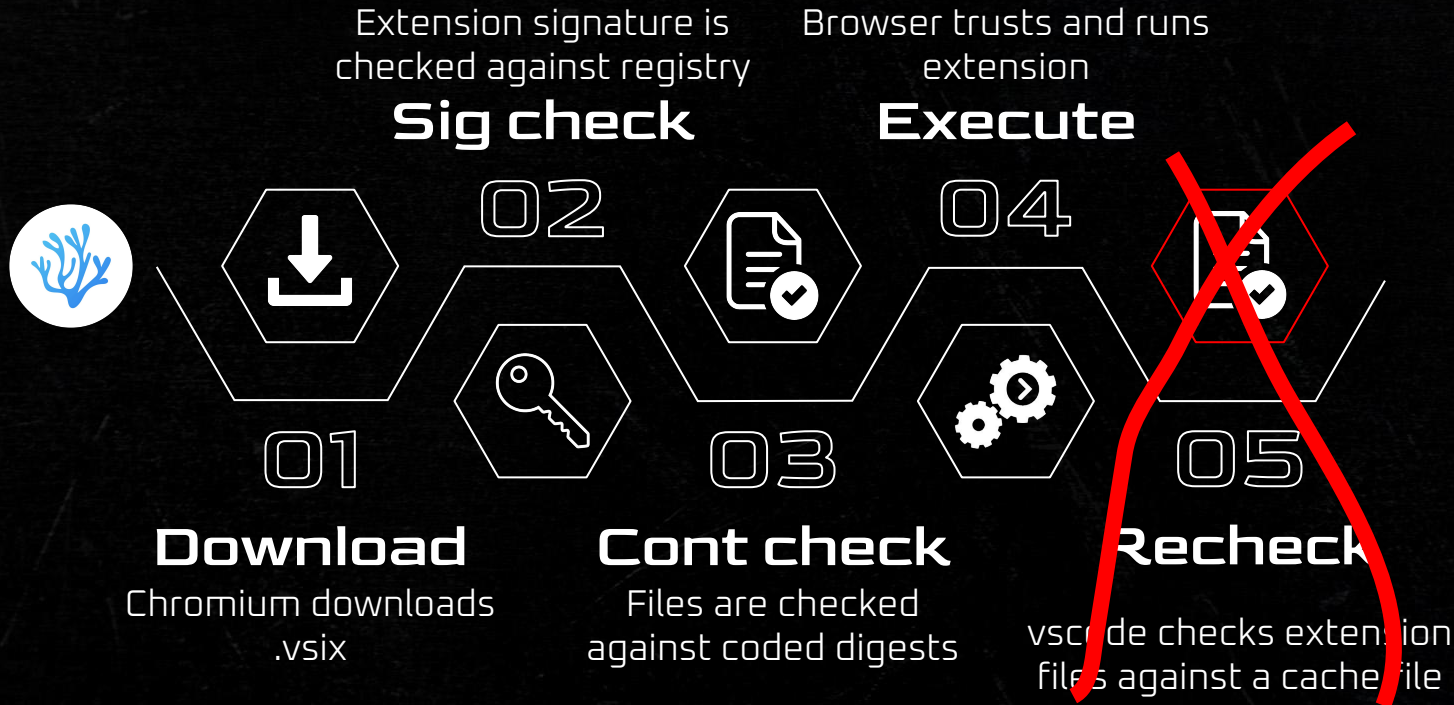
Extension lifecycle



Extension lifecycle



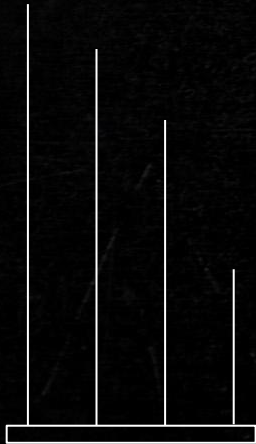
Extension lifecycle



Extension lifecycle



DEMO TIME



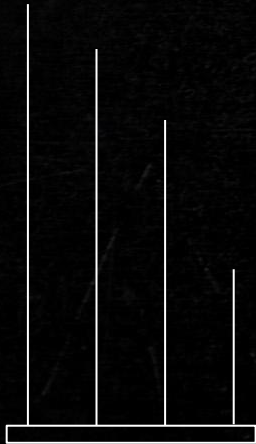
"One More Thing"



—SOMEONE RICH



DEMO TIME



Thanks

